

Security Incident Report

Cloudora Security Operations | Template CLD-IR-TEMPLATE | Complete every section. If a section is empty, write why.

Report ID	CLD-IR-0002
Related ticket	CLD-0002 — Reported phishing email impersonating Cloudora HR (payroll theme)
Report title	Payroll-themed credential phishing campaign; two accounts compromised via a lookalike portal
Analyst	Uju, SOC Analyst, Cloudora engagement (MyFirstHack training)
Date of report (UTC)	2026-08-25
Incident severity	P1 -Two staff account confirmed compromised and actively signed into by an external attacker; live credential theft against a company holding customer payroll data
Status	Investigating / partial containment recommended — see Section 6 for which findings are directly confirmed vs. carried from guide narrative
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

Ticket CLD-0002 opened on 25 August 2026 after James Holt forwarded a payroll-themed email to the SOC. Warning that the wider organization may have received similar messages impersonating Cloudora HR with a fake payroll update request. Investigation confirmed this was a phishing campaign designed to steal employee login credentials through a fake payroll website, and a separate marketing email flagged at the same time was checked and confirmed to be genuine, unrelated correspondence. One employee, Ryan Boyd, clicked the link and entered his password; records show his account was then accessed from an unfamiliar device in Amsterdam, Netherlands, shortly afterward, while he was still working normally from London, indicating the attacker used his stolen password to log in. A second employee, Freya Lynn, may have been affected in the same way and is being urgently checked to confirm. Ryan Boyd's account is being locked down immediately, and thirty other staff who received the email but did not click are being notified so they stay alert; the business risk is that any successful account takeover could expose employee or payroll data, but no evidence of further misuse has been found so far, for an awareness notice. A Mailchimp-sent newsletter reported alongside the phish was checked against the same authentication test and cleared as legitimate, since it aligns to the genuine cloudora.io domain rather than a lookalike.

2. Incident timeline

Every significant event in order, all times in UTC. Include attacker actions, victim actions, and response actions. Cite the log source for each row - a timeline entry you cannot evidence does not belong here.

Time (UTC)	Source	Event	Evidence / notes
Aug 25, 08:10:14	Msg trace	PayrollPhish-A delivered to ryan.boyd@cloudora.io	RecipientAddress=ryan.boyd

Aug 25, 08:36:24	Msg trace	PayrollPhish-B delivered to ryan.boyd@cloudora.io	CloudoraMsgTrace_CL
Aug 25, 09:05:44	Msg trace	ryan.boyd clicks the PayrollPhish-B link (https://login.cloudora-hr-portal.example/verify) from his own London IP (203.0.113.10) and CredentialsSubmitted = Yes	CloudoraMsgTrace_CL
Aug 25, ~09:11	Ticket	james.holt forwards the reported email to the SOC; ticket CLD-0002 raised	
Aug 25, 08:12:48	Sign-in	ryan.boyd's genuine sign-in: Outlook Web App, 203.0.113.10, London, iOS 17 / Mobile Safari — baseline device	CloudoraSignIn_CL search Ryan.boyd
Aug 25, 13:22:05	Sign-in	Sign-in as ryan.boyd from 198.18.7.200, Amsterdam, on Microsoft 365 — Windows 11 / Chrome, a device/location never seen before on this account. Judged to be the attacker using the harvested password (T1078)	CloudoraSignIn_CL
Aug 25, 13:25:33	Sign-in	Same Amsterdam session continues into Outlook Web App	CloudoraSignIn_CL
Aug 25, 13:43:49	Sign-in	Ryan.boyd's genuine device (iOS 17, London) signs in again — only 18 minutes after the Amsterdam sign-in, which is not physically reachable in that time (impossible travel)	CloudoraSignIn_CL
Aug 25, ~14:00	Response	Containment executed on both accounts	CloudoraSignIn_C / Recommendation

3. Findings

Finding 1 ryan.boyd@cloudora.io was delivered both variants, clicked variant B, and submitted credentials

A direct query against CloudoraMsgTrace_CL filtered to ryan.boyd@cloudora.io returns three rows: delivery of PayrollPhish-A at 08:10:14, delivery of PayrollPhish-B at 08:36:24, and a Click event on PayrollPhish-B at 09:05:44 (URL <https://login.cloudora-hr-portal.example/verify>, ClickIP 203.0.113.10 — his own London IP), with CredentialsSubmitted = Yes. His password should be treated as compromised from this point.

Finding 2 ryan.boyd's account was then accessed from a device and location it has never used

A full sign-in history for ryan.boyd@cloudora.io shows only two patterns: his genuine device (iOS 17 / Mobile Safari, London, IP 203.0.113.10) at 08:12:48 and 13:43:49, and a Windows 11 / Chrome sign-in from 198.18.7.200 in Amsterdam at 13:22:05 and 13:25:33. A summarised view (grouped by country/city/browser/device/IP) confirms these are the only two device/location clusters that have ever appeared on the account — there is no history of Amsterdam or of that device. The Amsterdam sign-in sits

18 minutes before the next genuine London sign-in, which is not physically possible (impossible travel) and, combined with Finding 4, is judged to be the attacker signing in with the harvested password shortly after the click — use of valid credentials, MITRE ATT&CK T1078.004.

Finding 3 The campaign used at least three sending IPs across two domains

Variant A was sent from two IPs in the same /24 (198.18.44.10 and 198.18.44.23); variant B was sent from a third IP, 198.18.51.7. All three, plus the lookalike domain cloudora-hr-portal.example, are treated as one campaign's infrastructure. Evidence: Received-header IPs across the four phishing .email samples.

Finding 4 The near-miss population is 30 accounts that received the phish but did not click

Comparing the distinct list of recipients with a Delivery event (DeliveryAction = Delivered) against the distinct list of recipients with a Click event returns 30 accounts that were delivered a copy and never clicked: adam.clark, alba.vega, amelia.frost, aria.reid, arjun.mehta, cole.burke, daniel.reeve, dean.page, ethan.wells, felix.hart, finn.gale, gwen.muir, isla.grant, james.holt, joel.kerr, jude.ross, kian.patel, leah.stone, lena.voss, liam.doyle, lucas.ford, mira.shah, noah.bishop, olivia.kaur, omar.farah, priya.nair, rhys.owen, sofia.marino, tara.kemp, zara.aziz (all @cloudora.io). These form the population for awareness communications, distinct from anyone who clicked.

Finding 5 The reported mailchimp newsletter passes authentication for the genuine cloudora.io domain and is cleared

The newsletter forwarded alongside the phish (03_benign_mailchimp_newsletter.eml) shows spf=pass, dkim=pass (aligned to both cloudora.io and Mailchimp's mcsv.net), and dmarc=pass action=none, with a working List-Unsubscribe header and links to Cloudora's real list-manage domain. This one passes for the real cloudora.io, not a lookalike. Verdict: legitimate marketing mail, not part of the attack.

4. Indicators of compromise (IOCs)

Type	Value	First seen (UTC)	Context
Domain	cloudora-hr-portal.example	Aug 25, 08:04-08:20	Lookalike of cloudora.io used by both variants; hosts the credential-harvest page (Step 3)
URL	https://cloudora-hr-portal.example/payroll/login	Aug 25, 08:47:12	Variant A harvesting link, per header/body analysis
URL	https://login.cloudora-hr-portal.example/verify	Aug 25, 09:05:44	Variant B harvesting link — confirmed clicked by ryan.boyd
IPv4	198.18.44.10	Aug 25, 08:04-08:20	198.18.44.10
IPv4	198.18.44.23	Aug 25, 08:35-08:50	Variant A sending relay, same /24 (email Received header)

IPv4	198.18.51.7	Aug 25, 08:35-08:50	Variant B sending relay
IPv4	198.18.7.200	Aug 25, 09:11	Sign-in IP from Amsterdam that accessed ryan.boyd's account at 13:22:05 / 13:25:33; not part of his normal device/location history (screenshot, sign-in query)
Sender	payroll@cloudora.io (spoofed)	Aug 25, 08:39:03	Forged From on variant A; Reply-To redirects to hr-support@cloudora-hr-portal.example
Sender	payroll@cloudora-hr-portal.example	Aug 25, 09:05:44	Variant B From address, the lookalike domain itself

5. MITRE ATT&CK; mapping

Tactic	Technique ID	Technique name	Evidenced by
Initial Access	T1566.002	Phishing: Spearphishing Link	Findings the two phishing variants, their links, and their sending infrastructure
Credential Access	T1598.003	Phishing for Information: Spearphishing Link	The credential-harvesting page described behind both links
Initial Access	T1078.004	Valid Accounts: Cloud Accounts	Finding ryan.boyd's account accessed from an unrecognised device/location shortly after his credential submission

6. Scope

Accounts confirmed compromised (2)

ryan.boyd@cloudora.io — confirmed by direct query: clicked and submitted credentials at 09:05:44, then accessed from an unrecognised device/location at 13:22:05 with impossible travel against his genuine sign-ins and freya.lynn@cloudora.io.

Accounts clicked but not confirmed compromised (4)

Four further staff clicked the link without submitting credentials and showed no anomalous sign-in. The staff are seth.lane, chloe.price, hugo.marsh, dina.said - clicked the link, no credentials submitted, no anomalous sign-in. Precautionary reset and direct check-in.

Accounts targeted but not compromised (34, directly verified)

Thirty accounts received a delivered copy of the phish and never clicked (Near-miss list) candidates for awareness communications rather than a forced reset. Four more (emma.hayes, maya.chen, nina.cole, ruth.dean) had every copy quarantined by EOP

Accounts / emails investigated and cleared, false positives (1)

The 'Cloudora Monthly' Mailchimp newsletter — legitimate marketing mail.

7. Actions taken

Time (UTC)	Action	Performed by	Verified how
Aug 25,~14:00-17:00	Revoke active sessions and refresh tokens for ryan.boyd@cloudora.io freya.lynn@cloudora.io	Cloudora SOC	Kills any live attacker session immediately, a password reset alone leaves an existing session working
Aug 25,~14:00-17:00	Reset credentials for the confirmed account(s)	Cloudora SOC	New passwords only matter once the stolen session is dead
Aug 25,~14:00-17:00	Require and re-register MFA on the affected account(s)	Cloudora SOC/ IT	The account fell to a password alone; MFA stops a harvested password being enough next time
Aug 25,~14:00-17:00	Block the sending relays (198.18.44.10, 198.18.44.23, 198.18.51.7), the sign-in IP (198.18.7.200), and the domain cloudora-hr-portal.example (all subdomains) at the mail gateway and web proxy	Cloudora SOC	Cuts off sending, hosting, and the attacker's login path
Aug 25,~14:00-17:00	Purge delivered copies of both variants from all mailboxes (soft delete / ZAP)	Cloudora SOC	Stops any of the 30 near-miss recipients clicking a copy still sitting in their inbox
Aug 25,~14:00-17:00	Re-run the sign-in and attacker-IP queries after containment to confirm no further 198.18.7.200 activity	Cloudora SOC	Containment is a claim until it is proven again in the logs, not assumed from the first pass

8. Recommendations

What the client should change so this attack fails next time. Be specific and prioritised: quick wins first, then strategic changes. Every recommendation should trace back to a finding.

- Password reset for the four who clicked and a direct check-in.

Subject: Action needed: password reset following this morning's phishing email

Hello [First name],

Our records show you clicked a link in the phishing email that went round this morning (the fake 'payroll update' message). You do not appear to have entered any login details, which is good.

As a precaution, we are resetting your password now, and you'll be asked to sign in again shortly. Please do not enter your Cloudora password on any site you reached from that email link.

If you did enter any details, or anything about your account looks unfamiliar (unexpected sign-in prompts, changed settings, etc.), please let IT Security know right away, you won't be in trouble, we just need to check.

Thanks for your patience,

Cloudora IT Security

- Send awareness communications to the 30-account near-miss list, and identify + directly contact anyone who clicked without submitting credentials.

Subject: Phishing alert: fake payroll email circulating today

Hello everyone,

An email went out this morning pretending to be from Cloudora HR, with the subject line "Payroll update: action required." It asked people to confirm their payroll details on a linked website. That email did not come from us, it's a phishing attempt, and we've already removed it from mailboxes.

No action is needed on your part. However, if you clicked the link or entered any information on that site, please contact IT Security right away. You won't be in any trouble we just need to help you secure your account quickly.

Just a reminder: Cloudora will never ask you to verify your password or bank details through a link in an email. To access your payslip or update your banking information, always sign in directly at myhr.cloudora.io.

Thanks for helping us keep Cloudora secure.

Best,
Cloudora IT Security

- Enforce MFA tenant-wide and disable legacy authentication paths that bypass it — the confirmed compromise was password-only.

- Move cloudora.io's DMARC policy to p=reject so spoofed mail like variant A is rejected outright rather than merely quarantined.
- Add mail-gateway detection for newly-registered lookalike domains, and for mail claiming to be from cloudora.io that fails DMARC.
- Build a detection rule correlating a phishing-link click with a successful sign-in from a new device/country within a short window afterward — this is exactly the pattern that identified Ryan Boyd's compromise, and automating it would catch the next one without waiting on a forwarded email.

// Rule: phishing-link click followed by a sign-in from an unexpected location

```
let LookbackWindow = 6h;
let TrustedCountries = dynamic(["United Kingdom", "United States"]); // adjust to Cloudora's actual footprint

let Clicks = CloudoraMsgTrace_CL
| where EventType == "Click"
| project ClickTime = TimeGenerated, UserPrincipalName = RecipientAddress, Url, ClickIP;

CloudoraSignIn_CL
| where ResultType == "0" // successful sign-in only
| join kind=inner Clicks on UserPrincipalName
| where TimeGenerated between (ClickTime .. (ClickTime + LookbackWindow))
| where IPAddress != ClickIP // not just the user carrying on from their own device
| where Country !in (TrustedCountries) // outside Cloudora's normal footprint
| project UserPrincipalName, ClickTime, SignInTime = TimeGenerated,
  IPAddress, Country, City, DeviceOS, Browser, Url
| order by SignInTime asc
```

9. Lessons learned

A single forwarded email (James Holt's report) was enough to open the ticket and, once the message trace and sign-in logs were queried, to fully scope one confirmed compromise directly from the data rather than from a description of it.

The authentication-passed-but-for-which-domain distinction it is what separates the phishing variant B from the legitimate newsletter, and it's worth stress-testing on every reported email, not just the obvious spoof.

Investigating Ryan Boyd's account was a useful test of the "click doesn't equal compromise, but click plus a later sign-in from somewhere unfamiliar does" logic, and a few things stood out:

Confirming compromise took three separate checks, not one. The click event alone (09:05:44, credentials submitted) only proved his password was exposed — it didn't prove the account had actually been used by someone else. It took pulling his full sign-in history and then summarizing it by device/location to establish that Amsterdam and the Windows/Chrome device had never appeared on his account before. Without that baseline step, the Amsterdam sign-in on its own would have been a maybe, not a confirmed compromise.

The timing gap was the tell, not just the location. Eighteen to twenty-one minutes between a genuine London sign-in and the Amsterdam one is what made this impossible travel rather than just "unusual." If the two sign-ins had been hours apart, the case for compromise would have been weaker and harder to argue in a report — the value of pulling the full timeline rather than just the suspicious row is that it shows the genuine activity bracketing the attacker's session.

The gap that matters most: detection speed, not detection accuracy. Once queried, the compromise was obvious and unambiguous. The four-hour delay between the attacker's sign-in (13:22) and the investigation catching it was entirely due to waiting on a human to forward an email not because the data was hard to read. That's the strongest argument for automating the click-then-new-device/country correlation rule rather than treating this kind of investigation as a manual, reactive process.

Template notes: keep all times UTC; write findings as you work, not at the end; the executive summary is written last but appears first. Completed example for this scenario: report CLD-IR-0001.